

OperatorOS Ecosystem Go-Live Readiness Audit

Executive readiness decision, verified evidence, security and visual review, architecture assessment, module launch matrix, and owner/Codex execution runbook.

RELEASE DECISION

HOLD

Source/local evidence is strong. Exact-commit CI, deployed identity, two live host auth paths, and owner-controlled production acceptance remain open.

REVIEWED SOURCE	e900e1d34195bcde45a4aff039778c756f47a226
LIVE SOURCE	211e270cbba7ca1af2617daad30eabab1e747c08
DATABASE	Release v56 / 56 ordered steps
SCOPE	13 products, platform authority, deployment, providers, data, operations

Assessment date: 2026-08-27 (America/New_York)
Prepared from current source, local verification, exact GitHub artifacts, approved visual baselines, and production-safe live checks.

CONTROLLED HANDOFF: This report does not authorize publication, provider mutation, DNS mutation, production migration, customer charging, or data cutover.

Readiness at a glance

SOURCE / LOCAL	EXACT CI	LIVE	DECISION
PASS	13/14 - BLOCKED	43/47 - BLOCKED	HOLD

TECHNICAL RELEASE BLOCKERS 1. Exact current GitHub run is red: 1,201/1,203 API tests. 2. Live commit does not match reviewed main. 3. Deploy Ops and Script Ops return anonymous HTTP 200. 4. Independent Deep Scan needs an updated Codex executable.	OWNER PRODUCTION GATES 1. Freeze launch scope, prices, providers, and kill switches. 2. Verify secrets, backup, isolated restore, and rollback owner. 3. Publish exact commit and approve v56 apply. 4. Accept deployed users/tenants, providers, data, monitoring, and policy.
---	--

REVIEWED MAIN	LIVE	PUBLIC CONTRACT
e900e1d...	211e270...	43 / 47 pinned checks

The source is release-capable, but the exact current GitHub run is red and production does not match the reviewed source. Two live module hosts also fail the anonymous authentication contract.

Contents

1. Executive overview	5
High-level work left for Codex	5
High-level work left for the owner	5
2. Current release gate matrix	6
3. Evidence collected in this audit	6
3.1 Source, CI, and live identity	6
3.2 Fresh local verification on e900e1d...	7
4. Architecture and structure audit	7
4.1 Architecture outcome	7
4.2 Central authority model	8
4.3 Structural risks to manage, not rewrite	8
5. Security audit	8
5.1 Security controls verified	8
5.2 Dependency and supply-chain position	9
5.3 Security gaps before a full public launch	9
6. Visual and accessibility audit	10
6.1 Automated visual evidence	10
6.2 Human review outcome	10
6.3 Non-blocking visual polish backlog	10
7. Module-by-module launch matrix	10
8. Detailed Codex-owned work plan	11
C1. Stabilize the current-commit tenant-messenger CI gate - blocker	11
C2. Correct live Deploy Ops and Script Ops anonymous authorization - blocker	12
C3. Reconcile release truth documents - required before sign-off	12
C4. Remove the pg concurrent-query deprecation - pre-upgrade debt	12
C5. Rerun independent deep security coverage - high-assurance gate	12
C6. Final candidate and deployed acceptance rerun - final Codex gate	12

9. Detailed owner go-live runbook

13

O1. Freeze launch scope and feature flags

13

O2. Inventory, verify, and rotate production secrets

13

O3. Prove production backup and restore before migration

13

O4. Approve and execute the supported v56 release path

14

O5. Verify exact live identity before customer traffic

14

O6. Complete deployed two-user/two-tenant acceptance

14

O7. Accept each live provider with controlled transactions

14

O8. Reconcile and cut over standalone data

15

O9. Complete commercial, policy, and support readiness

15

O10. Establish operations, monitoring, and rollback authority

16

O11. Final decision record

16

10. Recommended execution order

16

11. Definition of go-live complete

16

12. Limitations and assurance statement

17

13. Key evidence references

17

14. Release sign-off record template

18

Minimum release-room questions

18

Assessment date: 2026-08-27 (America/New_York) **Repository:** C:\Dev\OperatorOS **Reviewed source identity:** e900e1d34195bcde45a4aff039778c756f47a226 **GitHub branch:** main, synchronized with origin/main **Live source identity:** 211e270cbbba7ca1af2617daad30eabab1e747c08 **Decision:** HOLD - do not declare the ecosystem fully live yet

1. Executive overview

OperatorOS is a strong source/local release candidate, not an accepted production release. The core architecture is coherent, the centralized identity/tenant/billing authority is preserved, the database release is additive and rehearsed, all 7,396 compiled parity capabilities are implemented or backed by tested shared equivalents, and the current source passes a very broad local functional, security, accessibility, responsive, and visual test program.

The remaining work is much smaller than the implemented ecosystem, but it is release-critical:

1. The exact current commit is red in GitHub CI because two tenant-messenger presence tests failed on Linux. The same 1,203-test API suite passed locally, so the evidence points to a timing/lifecycle race, not an accepted waiver.
2. Production is not running the reviewed commit. It reports 211e270..., while local/GitHub main is e900e1d....
3. The live Deploy Ops and Script Ops hosts return an anonymous HTTP 200 where the exact-host security contract requires an authentication redirect.
4. Production backup/restore evidence, v56 apply evidence, deployed authenticated multi-user/tenant acceptance, real provider transactions, any required source-data cutover, monitoring/rollback proof, and the final commercial/legal launch decisions are still human-controlled gates.
5. The independent Codex Security Deep Scan could not start because the installed Codex executable cannot expose the required read-only worker permission profile. TAC access was subsequently confirmed granted at level tac1, so access is no longer a limitation; the executable compatibility issue remains. The existing security evidence is substantial, but this report does not claim an exhaustive independent multi-pass deep scan.

High-level work left for Codex

- Stabilize the tenant-messenger realtime/presence lifecycle so the exact current commit passes CI without timing sleeps, skipped tests, or weakened assertions.
- Reproduce and correct the live Deploy Ops and Script Ops anonymous authorization behavior in source or deployment routing, then add/retain a regression assertion.
- Reconcile current release documents so stale historical blocker counts and older live identities cannot be mistaken for current truth.
- Clear the observed pg concurrent-query deprecation warning before a future pg 9 upgrade.
- After the owner updates the Codex desktop/CLI, rerun the independent Deep Security Scan using the now-confirmed TAC level tac1 access.
- After the owner supplies or authorizes the production context, rerun the complete release gate and deployed acceptance matrix against the exact frozen commit and record a final evidence ledger.

High-level work left for the owner

- Choose the launch scope and decide which provider-backed features are enabled on day one. Keep OutCall coming_soon unless its separate safety/provider acceptance is complete.
- Verify/rotate production secrets and provider accounts without placing credentials in Git or the report.
- Take and verify a production backup, prove a restore to a separate database, set an explicit rollback owner, and approve the v56 database apply.
- Publish the exact approved commit and verify live commit, build, and database-release identity before allowing traffic.
- Complete deployed synthetic acceptance with two users and two tenants, real provider tests, module data reconciliation/cutover where applicable, and monitoring/alert checks.

- Approve pricing, Stripe products, policies, privacy/retention, support, tax/refund, SMS/telephony consent, and healthcare-adjacent boundaries with the appropriate business/legal advisers.
- Make and record the final **PROMOTE**, **HOLD**, or **ROLLBACK** decision.

2. Current release gate matrix

Gate	Current evidence	Status	Go-live meaning
Git identity	Local <code>main</code> equals <code>origin/main</code> at <code>e900e1d...</code> ; work began from a clean branch and was fast-forwarded	PASS	The reviewed source identity is exact and current
Architecture and structure	One <code>pnpm</code> workspace/lockfile; central API/web runtime; 13 governed modules; imported source trees excluded from execution; one database-release authority	PASS	No structural rewrite is required before launch
Parity/product truth	7,396 capabilities; 4,281 native, 3,115 tested shared equivalents, 0 waived, 0 blocked	PASS	No recorded source parity blocker remains
Static security/hardening	1,291 tracked source files, 0 scanner findings; 1,238-component SBOM; 0 critical and 0 unresolved dependency advisories	PASS WITH LIMITATION	Strong automated evidence, but not a substitute for the blocked independent deep scan or deployed penetration testing
Local API and authorization	1,203/1,203 tests passed on disposable PostgreSQL 16	PASS	Identity, MFA, SSO, tenancy, RBAC, billing, webhooks, modules, invitations, and messenger paths passed locally
GitHub CI for exact commit	Run <code>33038869118</code> : 13/14 stages passed; API 1,201/1,203 with two messenger presence failures	BLOCKER	A red exact-commit gate cannot be waived because the parent commit was green
Database release	<code>v56</code> , 56 ordered additive/idempotent steps; clean apply/reapply and 28/28 integration tests passed locally	PASS LOCALLY	Production backup, apply, reconciliation, and restore/rollback proof remain pending
Production build	<code>Next.js 15.5.23</code> ; API, runner, web, and native typechecks passed; 34 web pages generated	PASS LOCALLY	Artifact builds, but exact deployed identity remains unproven
Route/control integrity	223 active target files, 1,304 route capabilities, 964 crawl routes, 0 failures	PASS	Static navigation/control coverage is complete
Functional/browser/accessibility	21/21 exact-host compiled-production tests passed	PASS LOCALLY	Strong user-workflow/WCAG proof; deployed authenticated repetition remains pending
Visual contracts	13 modules; 78 approved Linux/Windows responsive hashes; 4/4 immutable visual tests	PASS LOCALLY	No critical source visual defect was found; live visual acceptance is still environment-dependent
Live runtime identity	Live commit <code>211e270...</code> , build <code>a032966d7e04a2986ce0d907</code> , DB <code>v56/56</code>	BLOCKER	Production is not the exact reviewed source identity
Live public/anonymous verification	43/47 pass when pinned to <code>e900e1d...</code>	BLOCKER	Two identity checks and two module-host authorization checks fail
DNS	All 17 expected hosts resolved to <code>34.111.179.208</code>	PASS	Resolution is present; application security behavior still controls acceptance
Live providers	Stripe, email, Twilio, and OpenAI report configured; shared provider control plane reports <code>not_configured</code>	PENDING	Configuration is not proof of a completed signed callback, transaction, reconciliation, or rollback
Production data/cutover	Dry-run tooling exists; no authorized production export/apply/reconciliation record was created in this audit	PENDING	Every imported standalone dataset needs explicit mapping, counts, reconciliation, and rollback
Monitoring/operations	Health/readiness are live; production alert, on-call, recovery, and observation evidence not accepted here	PENDING	Launch needs named owners, alert paths, support, and rollback authority
Legal/commercial	Not technically verifiable from the repository	OWNER/ADVISER	Policies, consent, pricing, tax/refund, and contractual claims need approval

3. Evidence collected in this audit

3.1 Source, CI, and live identity

- Local `main` was fast-forwarded from `0ab1090...` to `e900e1d...` and now equals `origin/main`.

- The only source-tree change between deployed `211e270...` and current `e900e1d...` is a blank-line publication marker in `.replit`; nevertheless, exact release identity remains a mandatory fail-closed gate.
- GitHub run `33038869118` for `e900e1d...` failed only the API stage. All other 13 stages passed, including the compiled browser suite and production preflight.
- The immediately preceding `0ab1090...` release-gate run `33036358826` passed. That makes a Linux-only test race likely, but does not make the current failure acceptable.
- Live `/api/health` and `/readyz` report commit `211e270...`, build `a032966d7e04a2986ce0d907`, and database release v56 with all 56 steps present.

3.2 Fresh local verification on e900e1d...

Verification	Result
Hardening/security wrapper	PASS
SBOM	1,238 components
Source security scan	1,291 files; 0 findings
Dependency audit	1,278 dependencies; 0 critical; 0 unresolved advisories
Exact high-advisory exceptions	2; both exact-GHSA allowlisted and protected by reviewed local patches/regression tests
Parity compiler	13 modules; 7,396 capabilities; 0 blockers/waivers
Typecheck	4/4 workspaces PASS
ESLint	PASS; 0 warnings
Unit tests	42/42 PASS
API tests	1,203/1,203 PASS; 0 skip/todo
Database/integration	28/28 PASS after v56 clean apply and reapply
Production build	PASS; 34 pages
Route/control integrity	1,304 capabilities / 964 routes; 0 failures
Functional/accessibility browser	21/21 PASS
Immutable visual suite	4/4 PASS

The API and integration tests ran against a newly created database named `operatoros_phase21_go_live_audit` in the existing disposable PostgreSQL 16 container. The container was returned to its original stopped state. No production database or customer data was read or changed.

Two non-product test-host limitations were also isolated:

- The sandboxed Windows process could not resolve the local user profile and emitted `uv_os_get_passwd returned ENOMEM`; the same read-only Node check outside the sandbox showed normal user lookup and ample memory. This was not an application memory failure.
- The first database attempt was rejected by the safety guard because its name did not include a disposable/test marker. The guarded database was not bypassed; a compliant isolated name was used.

4. Architecture and structure audit

4.1 Architecture outcome

The current ecosystem structure is suitable for launch and does not need a pre-launch rewrite:

- `apps/api` is the authoritative Fastify API for credentials, sessions, MFA, tenants, memberships, roles, subscriptions, billing, entitlements, module APIs, audit, database release, and readiness.
- `apps/web` is the Next.js public/auth/platform/module UI and exact-host routing surface.
- `apps/runner-gateway` remains disabled in production. Script Ops is a governed library and review workflow, not a browser/server remote shell.
- `packages/sdk` owns the public catalog/contracts, `packages/modules` owns registry/navigation policy, and `packages/sso` owns exact-host SSO primitives.
- `apps/modules/<slug>/source` is migration/provenance evidence outside the runnable pnpm workspace. Its child servers, locks, and migrations are not production authority.
- Root `pnpm-lock.yaml` is the only install authority. Production uses the pinned pnpm 10.34.5 path.
- `scripts/start-unified-runtime.mjs` is the Replit runtime authority and exposes one public web port while keeping API internals private.
- `apps/api/src/lib/database-release-contract.ts` is the single ordered database-release authority. Child `drizzle-kit push` or ad hoc schema directories are not supported.

4.2 Central authority model

```
Customer / operator
|
v
operatoros.net + app.operatoros.net
|
+-- credentials, MFA, platform session, tenants, roles
+-- subscription, add-on entitlement, module registry
+-- one-time exact-host SSO code (state + nonce + PKCE S256)
|
v
13 exact module hosts in the shared web/API runtime
|
+-- trusted server session supplies tenant/module authority
+-- every module read/write and audit is tenant-scoped
+-- provider actions remain signature-verified and fail-closed
```

This is the correct commercial boundary: OperatorOS remains the sole parent identity, tenant, platform billing, entitlement, and audit authority. Child modules may own their business data and provider operations but do not own credentials or platform subscriptions.

4.3 Structural risks to manage, not rewrite

- One deployment and one shared database for 13 products creates a larger blast radius. The correct mitigation is tested rollback, module kill switches, provider fail-closed controls, queue isolation, rate limits, and monitoring - not a rushed pre-launch service split.
- Current status documents contain historical red overlays and older identities alongside the new release gate. The top-level current release record is clear, but `PLANS.md` still calls an older plan current. This is documentation drift and should be reconciled before the release is signed.
- Imported standalone applications may still contain customer/source data not present in OperatorOS. Code parity does not prove data parity; each cutover requires a separate reconciliation record.

5. Security audit

5.1 Security controls verified

- Exact-host SSO uses opaque, short-lived, single-use authorization codes bound to client, callback, state, nonce, PKCE S256, tenant, module, environment, entitlement, and relative return path.

- Sessions are host-only, [Secure](#), [HttpOnly](#), [SameSite=Lax](#), and [Path=](#); module-local credentials, parent-domain cookies, localStorage bearer tokens, and JWTs in URLs are prohibited and covered by tests/contracts.
- Browser-supplied [X-Tenant-Id](#) is only a requested tenant selection and is revalidated against the server session.
- Module reads, writes, uniqueness, audit records, and transactions are tenant-scoped. Foreign tenant resources return non-enumerating denials.
- UI visibility is not treated as authorization; server role/entitlement checks control access.
- Stripe subscription/add-on billing remains OperatorOS-owned. Business payments such as TradeFlowKit Connect are separated by account, callback, webhook, idempotency, and settlement boundaries.
- Webhook paths verify provider signatures and use idempotency/replay protection. Client-side billing/provider state is not authoritative.
- MFA release v56 uses encrypted TOTP enrollment, one-way recovery-code hashes, bounded one-time login challenges, and single-use/failure controls.
- SnapProofOS upload/evidence paths enforce MIME/signature/scan/hash/custody controls; module-specific proof is covered in the API suite.
- PulseDesk explicitly warns against patient data/unnecessary PHI and its mobile UI keeps the boundary visible.
- CallCommand uses consent-first telephony boundaries, signed Twilio intake, protected associations, rate/replay controls, and fail-closed providers.
- OutCall is [coming_soon](#) and fails closed pending separate verified-self/safety/provider acceptance.
- Script Ops explicitly does not execute scripts in the browser, web server, or API process.

5.2 Dependency and supply-chain position

- A CycloneDX SBOM was generated with 1,238 components across 1,278 resolved dependencies.
- The dependency audit reported zero critical and zero unresolved advisories.
- Two disclosed high advisories are exact allowlisted exceptions: [GHSA-5p2g-fcmc-qvqq](#) and [GHSA-w3rx-r6r6-pgpr](#). The resolved versions are patched through checked-in reviewed patches and regression fixtures; the exception-integrity test is fail-closed.
- Security-relevant package overrides are pinned in the root workspace. The release gate installs from the frozen root lockfile.
- Production exposes one public port. API and worker services are private behind the shared runtime.
- No raw production credentials are committed in [.replit](#); the committed values are public hosts, modes, and Stripe price identifiers. Secret values remain provider-managed.

5.3 Security gaps before a full public launch

1. **Independent deep scan incomplete.** Codex Security Deep Scan returned a terminal preflight failure because `C:\Users\John Xodus\AppData\Local\Programs\OpenAI\Codex\bin\codex.exe` does not support the required `permissionProfile/list.allowed` API. No independent worker review, manifest, findings file, or coverage file was produced. Update Codex and run a new deep scan. TAC access was refreshed after enrollment and is now [granted](#) at level [tac1](#); TAC was not the scan-launch failure.
2. **No deployed authenticated attack simulation.** The live verifier is production-safe and mostly anonymous. It does not replace two-user/two-tenant authorization testing on the deployed target.
3. **No external penetration test.** The repository test program is strong, but an independent internet-facing authenticated assessment is still advisable before a broad paid/public launch or before contractual security claims.
4. **Provider credentials and callbacks are configured, not accepted.** Live readiness cannot prove webhook signature/replay handling, delivery, settlement, refund, opt-out, or provider account correctness.
5. **Secrets/access review pending.** Production deployer, database, Stripe, Twilio, email, OpenAI, GitHub/OAuth, backup, and DNS access should be inventoried and reduced to named least-privilege owners; stale credentials should be rotated.

6. **Privacy/legal verification pending.** PulseDesk must remain PHI-minimized unless a formally compliant architecture, agreements, controls, and policies are approved. Telephony/SMS, evidence retention, export/deletion, and customer data policies require owner/legal review.

6. Visual and accessibility audit

6.1 Automated visual evidence

- All 13 governed module visual contracts pass.
- Desktop, tablet, and mobile baselines exist for Linux and Windows: 13 modules x 3 breakpoints x 2 platforms = 78 approved reference images.
- All reference hashes are immutable in the release gate; snapshot updates are disabled during verification.
- Four additional immutable visual journeys pass.
- The exact-host functional browser suite passes 21/21 with accessibility, focus, overflow, navigation, and performance assertions enabled.
- Pinned self-hosted Inter and Open Sans fonts remove CDN and host-font substitution from production rendering.

6.2 Human review outcome

No critical clipping, broken hierarchy, invisible action, unusable denial, or brand-collision issue was found in the reviewed desktop/mobile reference set. The modules retain distinct product identities while using a consistent OperatorOS authority header and return/navigation model:

- TradeFlowKit uses a light revenue/operations layout with direct lead-to-cash actions.
- TechDeck presents an engineer-first operations console.
- PulseDesk presents a clinical operations surface and keeps its no-PHI warning prominent on mobile.
- TorqueShed, FaultlineLab, Operator Pool Hall, BrandForgeOS, SnapProofOS, StudyForge AI, Deploy Ops, CallCommand AI, and Script Ops retain distinct themes and clear product boundaries.
- OutCall shows a direct unavailable/access state rather than exposing an unaccepted safety workflow.

6.3 Non-blocking visual polish backlog

- The signed-in global header consumes substantial vertical space on small screens. It remains usable, but a later compact-header pass would improve information density.
- Some empty-state dashboards produce long mobile pages and large unused desktop areas. Progressive disclosure or denser first-use guidance would reduce scanning effort.
- The floating Contact control can overlap lower-right content in narrow layouts. Current tests did not show an inaccessible control, but safe-area/avoidance behavior should be refined.
- Synthetic organization names are intentionally long in test baselines and create header clutter. This is good stress coverage, not customer copy; production organization-label truncation should continue to be monitored.
- The live Deploy Ops and Script Ops authorization failures prevent those two deployed hosts from receiving a clean live visual/authentication acceptance, even though their local compiled visuals pass.

7. Module-by-module launch matrix

Product	Current source/local state	Additional launch requirement
TradeFlowKit	Full tenant-scoped quote-to-payment/business operations candidate; exact routes and visuals pass	Reconcile standalone data; accept public lead intake; validate Stripe Connect OAuth, signed webhook, payment, replay, refund, account/mode binding, and settlement if enabled

Product	Current source/local state	Additional launch requirement
PulseDesk	PHI-minimized healthcare operations candidate; mobile warning and workflows pass	Approve privacy posture; configure/accept mailbox/connectors if enabled; do not store PHI without formal compliance architecture and agreements; reconcile approved non-PHI source data
TechDeck	Complete MSP/IT operations candidate; public/private/mobile flows pass	Reconcile source data; validate any outbound connectors/attachments; keep command execution and secret reveal fail-closed
TorqueShed	Complete web/API product plus governed credit/Assist/payment contracts	Approve live Stripe credit catalog and webhook/reconciliation; accept OpenAI/Assist metering; set purchase kill switch only after controlled payment; complete native signing/app links/build identity if mobile ships
FaultlineLab	56 compiled challenges with server scoring and persistence; zero parity blockers	Confirm production catalog/restart persistence, AI/provider choice if used, and any source-data reconciliation
Operator Pool Hall	Practice, CPU, local, and protected online room workflows pass locally	Run deployed host/join/reconnect/replay/abuse-control acceptance with two authorized users; reconcile prior room/profile data if any
BrandForgeOS	Complete campaign/brand/AI/export candidate; metered workflows pass locally	Accept live OpenAI/shared-provider behavior, OAuth connectors if enabled, usage/billing reconciliation, export delivery, and source-data cutover
SnapProofOS	Complete evidence/custody/report/retention candidate	Accept production object storage, malware scanner, retention/legal hold, public sharing, export delivery, and source-data reconciliation
StudyForge AI	Complete source-grounded learning/assessment candidate	Accept live AI provider, usage/credit limits, upload/storage behavior, export delivery, and source-data reconciliation
Deploy Ops	Complete launch-readiness/workflow/export candidate; local auth/visual passes	Fix live anonymous HTTP 200; require auth redirect. Then accept live AI/provider paths and reconcile source data
CallCommand AI	Complete telephony/intelligence product plus bounded MSP intake candidate	Configure and accept Twilio number/signatures/callbacks/opt-in/STOP/country policy; accept BMS test/live boundaries, A2P/consent, monitoring, pricing, and reconciliation
Script Ops	Complete governed library/review/download/AI draft candidate; no execution	Fix live anonymous HTTP 200; require auth redirect. Then accept GitHub catalog synchronization, OpenAI drafting, immutable download/audit behavior, and source reconciliation
OutCall	Reconstructed verified-self safety workflow retained in source; catalog status is coming_soon	Recommended day-one state: hidden/unavailable. Activation requires separate source authority, safety/legal review, Twilio Verify/SMS/voice/DTMF signed callback acceptance, encrypted-secret review, monitoring, rollback, and explicit owner promotion

8. Detailed Codex-owned work plan

C1. Stabilize the current-commit tenant-messenger CI gate - blocker

Evidence: GitHub run [33038869118](#) passed 13/14 stages but failed two tests:

- [P53-REALTIME-001](#) timed out waiting for `presence.updated`.
- [P53-PRESENCE-001](#) then expected the second disconnect to make the user offline but received `false`.

Root-cause assessment: Medium confidence. The first failure is consistent with a socket readiness/event-order/lifecycle race on the slower Linux runner. The second failure is likely a cascade: after the first test times out, socket-close presence cleanup is asynchronous and can leave an active member connection when the direct presence test begins. The complete file passes locally, including both assertions.

Required implementation:

1. Reproduce under Linux/CI-like load and capture socket connection, registration, presence write, message send, and close cleanup ordering.
2. Add a deterministic server/client readiness contract or an awaitable test cleanup boundary. Do not add arbitrary sleeps, increase the timeout as the only fix, skip the test, or weaken the presence assertion.
3. Ensure the route cannot silently drop the initial presence event while still delivering `messenger.connected`.
4. Ensure WebSocket close cleanup completes before the application/test lifecycle advances.
5. Run the focused messenger file repeatedly, then all 1,203 API tests, then the full 14-stage release gate.
6. Require a green GitHub run on the exact frozen commit.

Exit criterion: 14/14 CI stages pass on the exact candidate, with 1,203/1,203 API tests and no skip/todo.

C2. Correct live Deploy Ops and Script Ops anonymous authorization - blocker

Evidence: <https://deployops.operatoros.net> and <https://scriptops.operatoros.net> return HTTP 200 to an anonymous request. The contract requires a 302/303/307/308 redirect into the exact-host PKCE login flow. Local compiled exact-host tests pass, so deployment snapshot, host routing, or middleware behavior is the likely boundary.

Required implementation/diagnosis:

1. Compare current catalog host mapping, middleware host classification, deployment environment aliases, and the live edge request headers.
2. Reproduce through the deployed hostname without credentials and inspect only non-sensitive redirect/diagnostic metadata.
3. Correct the shared routing/config/source defect without adding module-local login or bypass logic.
4. Retain regression coverage for anonymous redirect, entitled launch, non-entitled denial, deep link, return, and logout on both hosts.

Exit criterion: The current production verifier passes both module authorization checks and no other exact host regresses.

C3. Reconcile release truth documents - required before sign-off

Evidence: `docs/CURRENT_RELEASE_GATE.md` correctly reports the modern 7,396-capability candidate, while `PLANS.md` still labels older Phase 40/48 evidence as the current execution plan and older reports contain preserved historical blockers/identities.

Required implementation:

1. Add the current exact commit, GitHub run, live identity, 43/47 result, and known blockers to the current status ledger.
2. Mark historical sections clearly as superseded without deleting provenance.
3. Keep source/local, GitHub CI, provider build, DNS, database, deployed identity, authenticated live acceptance, data cutover, and provider acceptance as separate evidence fields.
4. Record exact commands, pass/fail/skip counts, environment, and rollback state.

Exit criterion: A release reviewer can identify the one current candidate and all remaining gates without interpreting historical overlays.

C4. Remove the pg concurrent-query deprecation - pre-upgrade debt

Evidence: Local API tests emitted `Calling client.query() when the client is already executing a query is deprecated and will be removed in pg@9.0` in TradeFlowKit retention/work-management paths.

Required implementation: Locate the overlapping query on one checked-out client and serialize it or use a separate transaction/client without weakening atomicity.

Exit criterion: The complete API suite passes without this warning, and the transaction/reconciliation behavior remains intact.

C5. Rerun independent deep security coverage - high-assurance gate

Owner prerequisite: Update the Codex desktop/CLI at the selected executable path so it supports the required read-only permission profile. TAC access is already confirmed `granted` at level `tac1`.

Codex action: Start a new independent Deep Security Scan on the whole repository, allow it to complete, seal its manifest/findings/coverage/report, triage any reportable findings, and verify fixes before signing the release.

Exit criterion: A completed scan report exists with explicit coverage and no unresolved critical/high reportable finding, or an owner-signed risk decision exists for any lower-severity accepted item.

C6. Final candidate and deployed acceptance rerun - final Codex gate

After C1-C5 and the owner-controlled deployment prerequisites:

1. Re-run hardening, parity, typecheck, lint, unit, API, integration/apply/reapply, production build, route/control, functional/accessibility browser, immutable visual, and production preflight gates.
2. Verify GitHub CI for the exact commit and record the run URL.

3. Verify production `/api/health` and `/readyz` exact commit/build/DB identity.
4. Run the production-safe public verifier and the authorized synthetic authenticated acceptance suite.
5. Record outcome as `PROMOTE`, `HOLD`, or `ROLLBACK`; never infer deployed success from source/CI alone.

9. Detailed owner go-live runbook

01. Freeze launch scope and feature flags

Decision required: Define the products and provider-backed workflows sold/advertised on day one.

Recommended starting position:

- Launch the 12 accepted catalog products only after the technical blockers clear.
- Keep OutCall `coming_soon`.
- Keep any unaccepted provider workflow visibly disabled/fail-closed rather than returning simulated success.
- Choose a controlled soft launch or beta cohort before broad paid traffic.

Record: enabled modules, disabled workflows, plan/add-on ownership, price/currency, customer cohort, go-live time, release owner, technical owner, rollback owner, support owner.

02. Inventory, verify, and rotate production secrets

Review provider-managed values for these categories without copying values into tickets, Git, screenshots, chat, or the PDF:

- Database URL and pool limits.
- `SESSION_SECRET`, `SSO_CODE_ENCRYPTION_SECRET`, shared secret encryption key, MFA encryption authority, and bootstrap credentials.
- OperatorOS root/app and all exact module host URLs.
- Stripe platform secret/webhook/account/price IDs; TradeFlowKit Connect client/webhook/redirect values; TorqueShed credit purchase controls.
- Email provider/from-domain and invitation delivery configuration.
- Twilio account/auth/public callback/number/signature/verification/country/consent configuration.
- OpenAI and any GitHub/OAuth/shared-provider credentials.
- Object storage/scanner credentials for uploads/evidence.
- DNS/provider/deployer tokens and backup/restore authority.

Exit criterion: every secret has an owner, purpose, least-privilege scope, rotation date, and successful fail-closed preflight; stale/demo credentials are revoked.

03. Prove production backup and restore before migration

OperatorOS uses one PostgreSQL authority for identity, billing, audit, SSO state, and all module data. Do not back up or migrate one active module independently.

1. Confirm provider-managed encrypted backup/PITR is healthy.
2. Create a fresh logical backup immediately before apply.
3. Encrypt it, record checksum, timestamp, source database identity, release identity, and restricted storage location.
4. Restore it into a separate non-production database.
5. Verify table counts and critical identity/tenant/billing/audit/module records.
6. Confirm initial recovery targets: RPO 24 hours and RTO 4 hours, or approve tighter paid-SLA targets.

7. Name the person authorized to restore and switch traffic.

Exit criterion: a verified provider snapshot plus checksum-verified logical backup and successful isolated restore record exist. A backup file alone is not restore proof.

O4. Approve and execute the supported v56 release path

1. Review `corepack pnpm db:plan`; require exactly 56 ordered steps ending in `auth_mfa_tables`.
2. Confirm the exact application candidate supports v56 MFA and invitation semantics.
3. Approve `OPERATOROS_DATABASE_RELEASE_MODE=apply` only for the controlled publish window.
4. Publish through `.replit` and `scripts/start-unified-runtime.mjs`; do not run imported child migrations or `drizzle-kit push`.
5. Preserve release/apply logs without secrets, MFA values, or customer data.

Rollback note: There is no destructive down migration. Restore into a new database and switch traffic after validation. Do not route v56-enrolled users to a v55 application.

O5. Verify exact live identity before customer traffic

Require all of the following to agree:

- approved Git commit;
- GitHub green run;
- deployed `/api/health` commit and build ID;
- `/readyz` ready state;
- database release 56/56, last step `auth_mfa_tables`;
- registry/exact-host diagnostics;
- provider mode/kill-switch expectations.

The current live identity (`211e270...`) is not acceptable for a release signed against `e900e1d...` or any later fix commit.

O6. Complete deployed two-user/two-tenant acceptance

Use synthetic accounts and test organizations, never a customer account:

1. Register/sign in, enroll MFA, test recovery code, sign out, and verify session revocation.
2. Create two tenants and at least owner/member/viewer roles.
3. Launch every enabled module through one-time exact-host PKCE SSO.
4. Test deep links, refresh, return to OperatorOS, local logout, global logout, and reauthentication.
5. Verify viewer/admin/write gates and non-entitled upgrade/denial states.
6. Attempt cross-tenant reads/writes and require non-enumerating denial.
7. Test invitation create-account, existing-login, Join, Decline, and delivered email link behavior.
8. Test tenant messenger presence, direct/group delivery, edit/delete/unread, multi-instance fan-out, membership revocation, and disconnect cleanup.
9. Test all enabled module primary workflows with persistence after reload/restart.

Exit criterion: all enabled hosts pass with no cross-tenant disclosure, privilege widening, session leak, dead CTA, fake success, or unexplained console/network error.

O7. Accept each live provider with controlled transactions

Minimum provider matrix:

- **Stripe platform billing:** subscription, add-on, webhook signature, duplicate replay, reconciliation, cancel/change, refund, invoice/receipt, and failed-payment path.
- **TradeFlowKit business payments (if enabled):** Connect onboarding, exact callback, account/mode binding, invoice link, signed webhook, idempotent settlement, duplicate/tamper rejection, refund/reversal, and ledger reconciliation.
- **TorqueShed credits (if enabled):** live catalog validation, Checkout/PaymentIntent, signed webhook, exactly-once credit settlement, insufficient balance, Assist reservation/final charge/release, refund/reconcile, and kill switch.
- **Email:** delivered invite, password/security email if applicable, bounce/failure handling, SPF/DKIM/DMARC alignment, and no sensitive content in logs.
- **Twilio/CallCommand:** exact [To](#) routing, signature verification, consent/opt-in, STOP/unsubscribe, country policy, callback replay, call/SMS failure, protected recordings, BMS outbox/reconciliation, and monitoring.
- **OpenAI:** allowed model, spend limit, timeout/error behavior, idempotent credit/usage accounting, redaction, and no provider-key leakage.
- **Uploads/storage/scanning:** authorized MIME/signature, malicious/quarantine path, private access, retention/legal hold, export, and deletion.
- **GitHub/OAuth/shared provider profiles:** exact redirect, state/nonce, tenant/admin ownership, token encryption/rotation/revocation, least privilege, and disabled-state honesty.

Use the smallest safe real transaction and refund/reverse it where applicable. Record provider IDs in a restricted evidence store, not this report.

08. Reconcile and cut over standalone data

For each module with prior standalone data:

1. Freeze source writes or define a delta window.
2. Export read-only and preserve source commit/schema/version provenance.
3. Run the module dry-run importer.
4. Review field mappings, tenant assignment, user linkage, redactions, conflicts, and rejected rows.
5. Back up the target again if required.
6. Approve apply explicitly.
7. Reconcile source/export/import counts and representative hashes/records.
8. Validate in the UI with authorized users.
9. Preserve rollback/switch instructions and do not destroy the source until retention approval.

Exit criterion: zero unexplained count difference, cross-tenant mapping, orphaned owner, secret import, or write-after-freeze drift.

09. Complete commercial, policy, and support readiness

Obtain appropriate business/legal review for:

- Terms of service, privacy notice, acceptable use, refund/cancellation, support expectations, and data processing/retention/export/deletion.
- Stripe products/prices, tier/add-on descriptions, tax/currency, invoices, receipts, trials, downgrade behavior, and failure handling.
- Telephony/SMS consent, A2P/registration where applicable, country restrictions, recording notice, opt-out, and emergency/non-emergency claims.
- PulseDesk no-PHI positioning. If PHI is ever introduced, pause and complete a formal compliance architecture and agreement review first.
- SnapProof evidence/custody/public-sharing claims and retention/legal hold behavior.
- OutCall safety language and explicit limitation; keep it unavailable until separately approved.

- Native mobile store/privacy/signing requirements if TorqueShed mobile is distributed.

O10. Establish operations, monitoring, and rollback authority

Before promotion, configure and test:

- uptime and exact-commit synthetic probes for root, app, API, and every enabled module host;
- API error rate, latency, database pool, queue/worker, webhook, payment, email, Twilio, OpenAI, upload/scanner, and SSO failure alerts;
- audit/log retention, redaction, correlation IDs, clock/timezone, and access controls;
- database backup/PITR failure alerts and quarterly restore schedule;
- incident severity, on-call/contact tree, customer support route, status communications, and vendor escalation;
- release rollback thresholds and one person with authority to call **HOLD** or **ROLLBACK**;
- a post-deploy observation window with no unrelated changes.

Exit criterion: alert delivery is tested, dashboards are visible to the named operators, rollback steps are accessible, and the observation window has an owner.

O11. Final decision record

At the end of the release window, record one decision:

- **PROMOTE:** all mandatory gates pass; enable the approved cohort/features.
- **HOLD:** preserve the current safe deployment/disabled state while a blocker is corrected.
- **ROLLBACK:** switch to the validated last-known-good application/database path and verify identity/readiness again.

The decision record should contain the exact commit, CI run, deployment/build, database release, backup/restore evidence reference, public/authenticated/provider test totals, open accepted risks, decision maker, time, and next review.

10. Recommended execution order

```
Codex: fix CI race + live host auth + docs + deep scan
|
v
Owner: freeze scope, providers, prices, secrets, owners
|
v
Owner: backup + isolated restore proof + rollback readiness
|
v
Codex: final local gate and exact green GitHub CI
|
v
Owner: publish exact commit and approve v56 apply
|
v
Codex + Owner: verify exact live identity, 47/47 public gate,
authenticated two-user/two-tenant journeys,
providers, data, monitoring, and visual acceptance
|
v
Owner: PROMOTE / HOLD / ROLLBACK
```

11. Definition of go-live complete

OperatorOS may be described as live only when all mandatory conditions below are evidenced for one exact release identity:

- local source gate green;
- exact GitHub commit and 14/14 CI stages green;
- zero unresolved critical/high security finding, with explicit coverage limits recorded;
- production backup and isolated restore verified;
- v56 apply successful and database identity current;
- deployed health/readiness commit and build match the approved source;
- every enabled exact host enforces authentication/entitlement and passes deep-link/logout behavior;
- deployed two-user/two-tenant authorization and persistence pass;
- approved live provider workflows complete, reconcile, fail safely, and can be disabled;
- any required data cutover reconciles with no unexplained differences;
- legal/commercial/support/monitoring/rollback owners approve;
- final decision record is [PROMOTE](#).

Until then, the accurate statement is:

OperatorOS is source/local release-ready with strong automated coverage; production promotion remains on hold pending exact-commit CI, exact deployed identity, two live host authorization repairs, and owner-controlled production/provider/data/operational acceptance.

12. Limitations and assurance statement

- This audit did not publish, mutate DNS, rotate secrets, charge a real customer, apply a production migration, import production data, or create/delete provider resources.
- Live checks were production-safe and read-only/anonymous. Authenticated live tests require owner-controlled synthetic credentials and explicit provider context.
- Provider readiness fields prove configuration presence, not successful end-to-end operation.
- Local compiled visual/browser evidence does not substitute for deployed browser acceptance on the exact commit.
- The Codex Security Deep Scan did not run because the installed Codex executable lacks the required read-only permission-profile API. No deep-scan finding or no-findings claim is made.
- Legal, tax, privacy, healthcare, telephony, and contractual items require qualified professional review; this technical report is not legal or compliance certification.

13. Key evidence references

- [docs/CURRENT_RELEASE_GATE.md](#)
- [docs/auth/OPERATOROS_SSO_CONTRACT_V1.md](#)
- [docs/OPERATOROS_ECOSYSTEM_INTEGRATION_CONTRACT.md](#)
- [docs/MODULE_CONSOLIDATION_STATUS.md](#)
- [docs/modules/MODULE_PARITY_INDEX.md](#)
- [docs/FINAL_E2E_ACCEPTANCE_REPORT.md](#)
- [docs/CROSS_MODULE_READINESS_REPORT.md](#)
- [docs/DATABASE_BACKUP_RESTORE.md](#)
- [docs/adr/README.md](#)

- PLANS.md
- packages/sdk/src/catalog.ts
- packages/modules/registry.ts
- .github/workflows/release-gate.yml
- .replit
- GitHub run: <https://github.com/shotgunsensei/OperatorOS/actions/runs/33038869118>
- Live health: <https://operatoros.net/api/health>
- Live readiness: <https://operatoros.net/readyz>

14. Release sign-off record template

Complete this record only after the remaining Codex and owner gates are executed. Store restricted provider, backup, customer, and credential evidence in the approved private evidence location; place only non-sensitive references here.

Sign-off field	Required value
Candidate commit	Exact 40-character Git SHA
GitHub release gate	Green run URL; 14/14 stages; exact test totals
Security	Deep-scan report reference; external assessment/risk decision; unresolved finding count
Deployment	Provider deployment ID, build ID, publish time, and operator
Database	Release 56/56; backup reference; checksum; isolated restore result; apply log reference
Live public gate	Exact commit/build/DB match; 47/47 or the then-current complete contract total
Authenticated acceptance	Two users; two tenants; enabled modules; role/tenant negative tests; logout/revocation result
Providers	Stripe, email, Twilio, OpenAI, storage/scanner, GitHub/OAuth acceptance references and kill-switch state
Data	Per-module export/import/reconciliation result and remaining source-write state
Operations	Monitoring/alert test, on-call owner, support owner, observation window, rollback threshold
Commercial/legal	Approved plans/prices/policies/consent/privacy/support references
Open accepted risks	Severity, owner, customer impact, mitigation, due date, approval
Final decision	PROMOTE, HOLD, or ROLLBACK; decision maker and timestamp

Minimum release-room questions

1. Does every evidence item identify the same exact commit, or is the release automatically on hold?
2. Can the team restore into a separate database and switch traffic without improvisation?
3. Can each unaccepted provider or module be disabled without exposing fake success or breaking central auth?
4. Did two synthetic tenants prove non-enumeration, role limits, persistence, revocation, and logout on the deployed target?
5. Are support, incident, provider, backup, and rollback owners actively reachable during the observation window?
6. Is the owner prepared to choose **HOLD** or **ROLLBACK** if any answer is uncertain?

Current pre-sign-off state: **HOLD**. This template is intentionally incomplete until the exact-commit CI, live identity, live host authorization, deep-scan tooling, production backup/restore, authenticated provider/data acceptance, monitoring, and owner approvals are complete.